

Reporte de Solución de Problemas Matemáticos
Evaluación de la Calidad del Software mediante Métricas, Verificación y Auditoría

Presentado por:

Andrés Steven Beltrán Forero

Asignatura:

NRC-93980 – Estándares y Métricas de Calidad en el Desarrollo de Software

Semana:

Semana 2

Docente:

César Alfonso Bolado Silva

Fecha de entrega:

12 de julio de 2026

Procedimiento realizado para la resolución del caso

Para desarrollar esta actividad, primero se realizó una lectura completa del caso de estudio con el fin de comprender el funcionamiento del sistema, los requisitos establecidos y las evidencias suministradas. Posteriormente, se revisaron la especificación de requisitos, la bitácora de incidencias, la lista de control de cambios y los resultados de las pruebas preliminares para identificar los aspectos que podían afectar la calidad del software antes de su salida a producción.

Después de analizar la información, se relacionaron los requisitos con las incidencias y los resultados de las pruebas para verificar cuáles cumplían lo esperado y cuáles presentaban fallas o estaban pendientes de validación. También se revisó el control de cambios para comprobar si las modificaciones realizadas habían sido revisadas y aprobadas antes de ser desplegadas.

Con la información obtenida se identificaron los principales hallazgos de seguridad y se definieron las actividades de verificación y validación que debían aplicarse al sistema. Además, se elaboró una lista de revisión técnica y un plan de auditoría con el objetivo de evaluar el cumplimiento de los requisitos y de las buenas prácticas de calidad del software.

Como referencia para la evaluación se utilizó el estándar **ISO/IEC 25010**, relacionando las características de calidad con los problemas encontrados durante el análisis. También se definieron diferentes métricas para medir aspectos como la cobertura de pruebas, el cumplimiento de requisitos, la disponibilidad del sistema y el estado de las incidencias críticas.

Finalmente, con toda la información recopilada se elaboraron las conclusiones y recomendaciones, priorizando las acciones necesarias para corregir los hallazgos identificados antes de la liberación del sistema. De esta manera, fue posible realizar una evaluación objetiva del nivel de calidad del software y proponer mejoras que contribuyan a ofrecer un producto más seguro, confiable y acorde con los estándares estudiados en la asignatura.

Matriz de Verificación y Validación

ID	Requisito / funcionalidad relacionada	Tipo (V/V)	Técnica a aplicar	Responsable	Criterio de aceptación	Evidencia esperada
RF-014	Autenticación 2FA	Verificación	Revisión de código + inspección de configuración	Líder técnico	2FA obligatorio para roles críticos	Acta de revisión y configuración exportada
RF-014	Autenticación 2FA	Validación	Prueba funcional con usuarios médicos	QA	El personal médico inicia sesión utilizando 2FA	Evidencia de ejecución de pruebas
RF-022	Cifrado AES-256 de la HCE	Verificación	Revisión de configuración criptográfica	Arquitecto de Software	Información almacenada cifrada	Configuración y documentación técnica
RF-022	Cifrado AES-256 de la HCE	Validación	Prueba de almacenamiento y consulta	QA Seguridad	No es posible visualizar datos sin descifrado autorizado	Evidencia de pruebas
RF-031	Tiempo de respuesta < 2 segundos	Verificación	Revisión de arquitectura y consultas SQL	Arquitecto	Diseño optimizado	Informe técnico
RF-031	Tiempo de respuesta < 2 segundos	Validación	Prueba de carga con 100 usuarios concurrentes	QA Rendimiento	Tiempo promedio $\leq$ 2 segundos	Reporte JMeter
RF-045	Registro de auditoría de accesos	Verificación	Revisión del módulo de auditoría	Líder Técnico	Todas las operaciones generan log	Acta de revisión
RF-045	Registro de auditoría de accesos	Validación	Prueba funcional sobre lectura y escritura	QA	Se registra usuario, fecha y operación	Evidencia de logs
RF-052	Cumplimiento PCI-DSS	Verificación	Revisión de configuración de la pasarela	Seguridad	No se almacena PAN completo	Informe de revisión
RF-052	Cumplimiento PCI-DSS	Validación	Pruebas del proceso de pago	QA Seguridad	Los registros muestran únicamente datos enmascarados	Evidencia de pruebas
RF-060	Canal de video cifrado	Verificación	Revisión de certificados TLS	Infraestructura	Configuración segura	Configuración del servidor
RF-060	Canal de video cifrado	Validación	Prueba de telemedicina	QA	Comunicación cifrada extremo a extremo	Informe de pruebas

Lista de Control de Revisiones Técnicas

N°	Ítem de revisión	Cumple	Observaciones / evidencia
1	El código fuente cumple con los estándares definidos.	N.A	Sin observaciones.
2	Existe trazabilidad entre requisitos y casos de prueba.	no	RF-031 y RF-060 no cuentan con casos de prueba ejecutados (ver 2.4).
3	Todos los cambios fueron documentados y aprobados antes del despliegue.	No	CR-202 y CR-205 fueron desplegados sin revisión registrada.
4	Los mecanismos de autenticación y autorización protegen los recursos críticos.	No	INC-101 evidencia un IDOR.
5	La información sensible se almacena y transmite cifrada.	No	RF-022 pendiente; INC-103 demuestra canal sin cifrar.
6	Existen registros de auditoría para accesos y modificaciones.	No	Solo se registran escrituras (RF-045, INC-105).
7	Se ejecutaron pruebas de seguridad (pentesting).	No	No ejecutadas por falta de tiempo.
8	Se ejecutaron pruebas de carga sobre módulos críticos.	No	Agendamiento y Telemedicina pendientes.
9	El tratamiento de datos personales cumple Ley 1581 de 2012.	No	Deben corregirse vulnerabilidades de acceso. INC-101, INC-102 y RF-022
10	La historia clínica cumple Resolución 1995 de 1999.	No	INC-101 y INC-105, debe fortalecerse la trazabilidad.
11	Telemedicina cumple Resolución 2654 de 2019.	No	INC-103, canal sin cifrado.
12	Existen alertas automáticas para procesos críticos.	No	INC-106, evidencia ausencia de alertas.
13	La documentación técnica y de usuario está actualizada.	N.A	Según control documental.
14	Los riesgos técnicos y regulatorios fueron mitigados antes de liberar.	No	Persisten hallazgos críticos abiertos.
15	Las cuentas privilegiadas son individuales.	No	Cuenta admin_ti compartida.
16	Las contraseñas administrativas poseen política de expiración.	No	No expiran.
17	Se verificó el cumplimiento PCI-DSS.	No	Auditoría pendiente.
18	Se validó el cifrado de la historia clínica.	No	RF-022 pendiente de verificación.

Formato Base de Auditoría

Hallazgo	Justificación	Impacto
IDOR en Historia Clínica	Permite acceder a información de otros pacientes.	Alto
Cuenta administrativa compartida	No existe trazabilidad del responsable.	Alto
Canal de video sin cifrado	Riesgo de interceptación de información médica.	Alto
Exposición del PAN en logs	Incumplimiento PCI-DSS.	Alto
Ausencia de auditoría de lectura	No permite detectar accesos indebidos.	Medio-Alto
Batch sin alertas	Puede retrasar la facturación sin ser detectado.	Medio
Pruebas de carga no ejecutadas	Riesgo de bajo desempeño en producción.	Medio

Hallazgos

N°	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
1	Vulnerabilidad IDOR permite acceso a historias clínicas de pacientes no asignados.	RF-045, ISO 25010, OWASP	INC-101	Alta	Implementar validaciones de autorización por objeto y repetir pruebas de seguridad.
2	Cuenta administrativa compartida y sin expiración de contraseña.	Política de Seguridad	INC-102	Alta	Crear cuentas individuales y aplicar MFA.
3	Canal de telemedicina transmitido sobre HTTP.	RF-060	INC-103	Alta	Configurar TLS y cifrado extremo a extremo.
4	Los logs almacenan el número completo de tarjeta.	PCI-DSS	INC-104	Alta	Enmascarar PAN y revisar registros históricos.
5	No existe trazabilidad de lectura de historias clínicas.	RF-045	INC-105	Media-Alta	Registrar eventos de lectura y auditoría completa.
6	Proceso batch falla sin alertas automáticas.	Buenas prácticas de monitoreo	INC-106	Media	Implementar monitoreo y notificaciones automáticas.
7	No se ejecutaron pruebas de carga.	RF-031	INC-107	Media	Ejecutar pruebas antes de liberar.
8	Cambios CR-202 y CR-205 fueron desplegados sin revisión ni aprobación registrada.	Gestión del Cambio	Lista de Cambios	Alta	Formalizar el proceso de aprobación antes del despliegue.

Hallazgos de Seguridad

Hallazgo	Justificación	Impacto
IDOR en Historia Clínica	Permite acceder a información de otros pacientes.	Alto
Cuenta administrativa compartida	No existe trazabilidad del responsable.	Alto
Canal de video sin cifrado	Riesgo de interceptación de información médica.	Alto
Exposición del PAN en logs	Incumplimiento PCI-DSS.	Alto
Ausencia de auditoría de lectura	No permite detectar accesos indebidos.	Medio-Alto
Batch sin alertas	Puede retrasar la facturación sin ser detectado.	Medio
Pruebas de carga no ejecutadas	Riesgo de bajo desempeño en producción.	Medio

Métricas

Métrica	Cálculo con los datos del caso	Criterio de aceptación
Densidad de hallazgos críticos	5 hallazgos de severidad alta / 8 funcionalidades críticas = 0.63	0 hallazgos de severidad alta abiertos antes del release
Cobertura de pruebas críticas ejecutadas	2 de 4 pruebas críticas ejecutadas (pentesting HCE y carga de telemedicina no ejecutadas) = 50%	≥ 100% de pruebas críticas ejecutadas antes del release
Tasa de cambios desplegados sin revisión	2 de 5 cambios (CR-202, CR-205) sin revisión registrada = 40%	0% de cambios desplegados sin aprobación
Fallos del batch sin alerta	3 fallos en 4 semanas sin generar alerta automática	100% de los fallos deben generar alerta (0 fallos silenciosos)
Disponibilidad en horario de atención	Criterio contractual 99.5% (7 a.m.–9 p.m.); sin medición formal reportada en el escenario	≥ 99.5% medido con monitoreo continuo

Conclusión

La auditoría evidencia que MediCitas presenta fortalezas funcionales; sin embargo, persisten hallazgos críticos relacionados con seguridad, cumplimiento normativo, gestión de cambios y pruebas no ejecutadas. No se recomienda la liberación a producción hasta corregir las vulnerabilidades identificadas, completar las pruebas críticas y validar el cumplimiento de los requisitos no funcionales establecidos.